Analyst: Alejandro Ramos

Date: May 29th, 2025

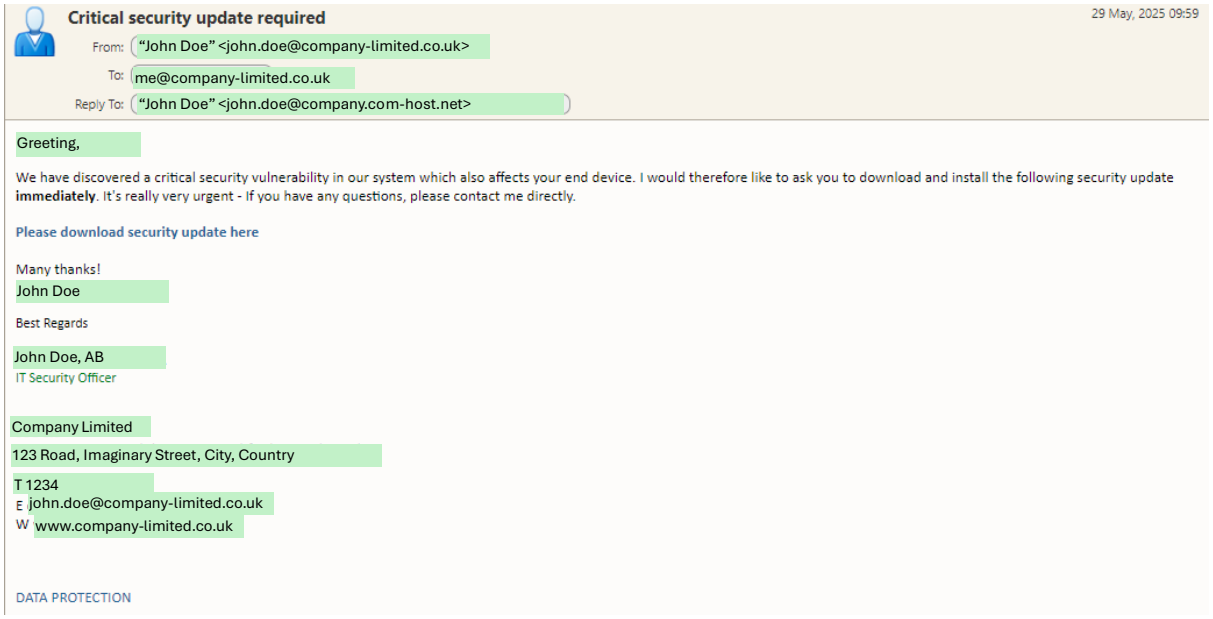
Type: Simulated Phishing (Company Awareness Test)

Medium: E-mail

Status: Reported

Description:

Received an internal-looking e-mail stating the need of a critical security update.



Critical security update required 29 May, 2025 09:59

From: "John Doe" <john.doe@company-limited.co.uk>

To: me@company-limited.co.uk

Reply To: "John Doe" <john.doe@company.com-host.net>

Greeting,

We have discovered a critical security vulnerability in our system which also affects your end device. I would therefore like to ask you to download and install the following security update **immediately**. It's really very urgent - If you have any questions, please contact me directly.

Please download security update here

Many thanks!
John Doe

Best Regards

John Doe, AB
IT Security Officer

Company Limited
123 Road, Imaginary Street, City, Country

T 1234
E john.doe@company-limited.co.uk
W www.company-limited.co.uk

DATA PROTECTION

Indicators of Phishing:

- "Reply-to" address does not match sender domain (Shown in screenshot). Indicator of possible spoofing.
- All hypertexts found in the e-mail directs to the same URL, which is a non-company domain. (See screenshot of original email).
- Language designed to call for action and trigger urgency ("It's really very urgent", "download and install the following", "immediately").
- No specific names or references to internal systems.
- Besides technicalities, downloading and installing a major security update will always be done by the Administrator. Usually, they would deploy the update to the computers via network, and there should not be any engagement from the user. This also makes the call to action suspicious.

Screenshots and Analysis:

- The From and Reply To email don't match. But more than that, if we take a closer look at the domain (indicated by the @ sign in an email) we can see that the Reply To email is "disguising" as the legitimate domain. In "company-limited.co.uk", company-limited is the domain name. However, in "company.com-host.net", company.com-host is the domain name.
- The TLD (Top Level Domain) ".co.uk" and ".net" are not the same.

```
  </head>
  <body>
    <div style=3D"font-family:Calibri,sans-serif;font-size:11pt;line-height=
:1.2">
              Greeting,          />
      <br />
      We have discovered=
 a critical security vulnerability in our system which also affects your =
end device. <span id=3D"i1">I would therefore like to ask you to download =
and install the following security update <b>immediately</b>.</span> <span =
id=3D"i2">It's really very urgent</span> - If you have any questions, =
please contact me directly. <br />
      <br />
      <a =
href=3D"https://externaldomain.com-host.net/en/?code=1A2abcde42a321dd0bb=
d9d67d978c90"><b>Please download security update here</b></a><br />
      <br />
      Many thanks!<br />
           John Doe      <br />
      <br />
      <div style=3D"font-family:Calibri,=
sans-serif;font-size:10pt;line-height:1.2">Best Regards</div><br />
      <b>      John Doe, AB      </b><br />
      <div =
style=3D"font-family:Calibri,sans-serif;font-size:10pt;line-height:1.=
2;color:green">IT Security Officer </div><br />
      <span id=3D"i3">
      <br />
     Company<br />
      123 Road, Imaginary Street,
       City, Country        <br />
      <br />
        T 1234  <br />
      E <a href=3D"https://externaldomain.com-host.net/en/?=
code=1A2abcde42a321dd0bb=          ">t      john.doe@company-limited.co.uk
uk</a><br />
      W <a href=3D"https://externaldomain.com-host.net/en/?=
code=1A2abcde42a321dd0bb=          ">www.company-limited.co.uk</a><br /></span>
      <br />
      <br />
      <br />
      <a href=3D"https://externaldomain.com-host.net/en/?=
code=1A2abcde42a321dd0bb=                    ">DATA =
PROTECTION</a><br />
      <br />
    </div>
```

- As you can see, all hyperlinks redirect the user who clicks on them to the same exact URL. No matter if we click the email, the supposed link to download the software update or the Data Protection policy. The person's intent is for us to click something. Anything.

Recommendation:

- Do not engage in any way. Mark as phishing and report.
- If part of the analysis team, inspecting the URL within a sandbox environment such as a Virtual Machine would be useful to identify what kind of threat is targeting the network.

Analyst: Alejandro Ramos

Date: July 4th, 2025

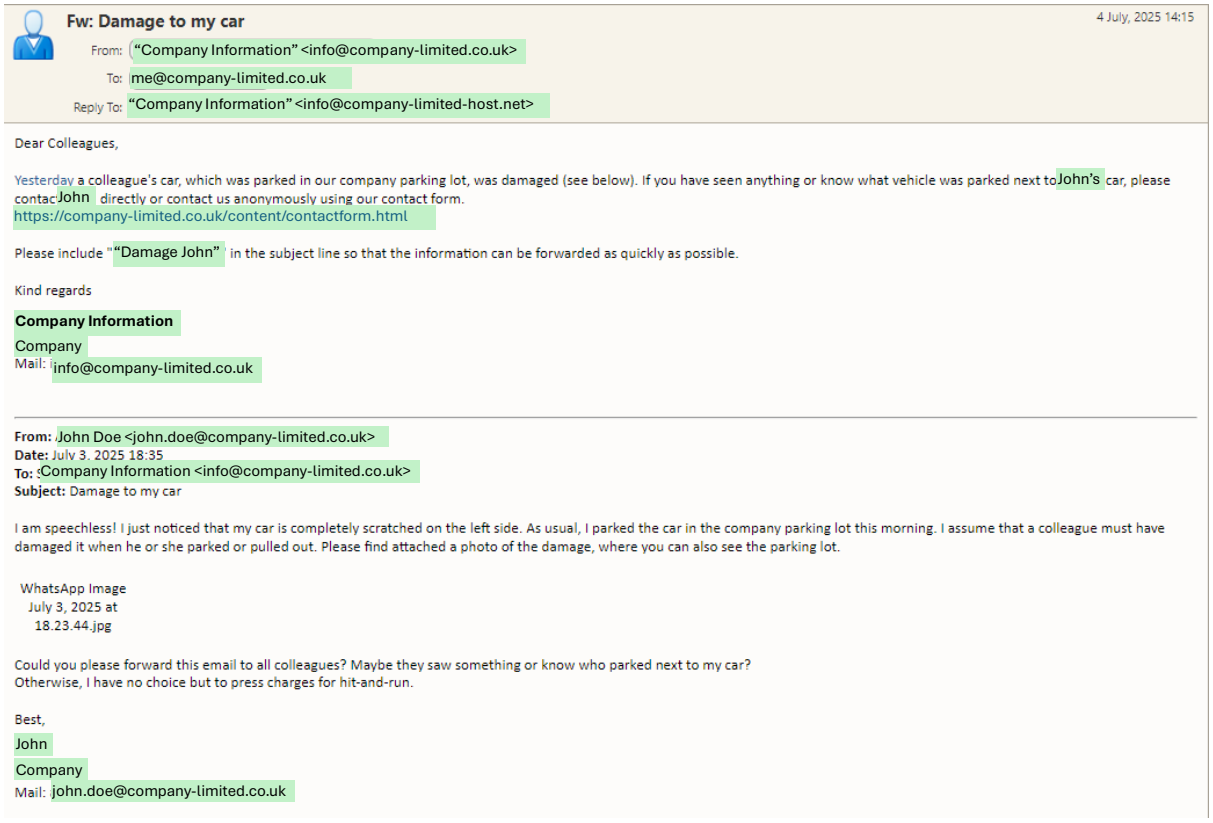
Type: Simulated Phishing (Company Awareness Test)

Medium: E-mail

Status: Reported

Description:

Received an internal-looking e-mail stating that one of the employees had her car scratched at the company parking lot. The e-mail prompts the user to forward it to “all colleagues” and attaches an image of the car to see the damages.



Fw: Damage to my car 4 July, 2025 14:15

From: “Company Information” <info@company-limited.co.uk>
To: me@company-limited.co.uk
Reply To: “Company Information” <info@company-limited-host.net>

Dear Colleagues,

Yesterday a colleague's car, which was parked in our company parking lot, was damaged (see below). If you have seen anything or know what vehicle was parked next to John's car, please contact John directly or contact us anonymously using our contact form.
https://company-limited.co.uk/content/contactform.html

Please include “Damage John” in the subject line so that the information can be forwarded as quickly as possible.

Kind regards

Company Information
Company
Mail: info@company-limited.co.uk

From: John Doe <john.doe@company-limited.co.uk>
Date: July 3, 2025 18:35
To: Company Information <info@company-limited.co.uk>
Subject: Damage to my car

I am speechless! I just noticed that my car is completely scratched on the left side. As usual, I parked the car in the company parking lot this morning. I assume that a colleague must have damaged it when he or she parked or pulled out. Please find attached a photo of the damage, where you can also see the parking lot.

WhatsApp Image July 3, 2025 at 18.23.44.jpg

Could you please forward this email to all colleagues? Maybe they saw something or know who parked next to my car?
Otherwise, I have no choice but to press charges for hit-and-run.

Best,
John
Company
Mail: john.doe@company-limited.co.uk

Indicators of Phishing:

- “Reply-to” address does not match sender domain (Shown in screenshot). Indicator of possible spoofing.
- All hypertexts found in the e-mail directs to the same URL, which is a non-company domain. (See screenshot of original email).
- Language and context designed to create curiosity and calls to action (click on image / forward email).

Screenshots and Analysis:

- The From and Reply To email don't match. But more than that, if we take a closer look at the domain (indicated by the @ sign in an email) we can see that the Reply To email is "disguising" as the legitimate domain. In "company-limited.co.uk", "company-limited" is the domain name. However, in "company-limited-host.net", "company-limited-host" is the domain name.
- The TLD (Top Level Domain) ".co.uk" and ".net" are not the same.

```
    <title></title>
  </head>
  <body>
    <div style=3D"font-family:Calibri,sans-serif;font-size:11pt;line-height=
:1.2">
      Dear Colleagues,<br />
      <br />
      Yesterday a =
colleague's car, which was parked in our company parking lot, was damaged =
(see below). If you have seen anything or know what vehicle was parked next=
 to John's  car, please contact John directly or contact us anonymously =
using our contact form. <br />
      <span id=3D"i1"><a =
href=3D"http://externaldomain.com-host.net/en/?code=3D843cdd2b5dd665ececb5=
9264ee8e5891 ">https://company-limited.co.uk/content/contactform.html .</a></span>
      <br /><br />
    Please include "Damage John"      in the subject line =
so that the information can be forwarded as quickly as possible.<br /><br =
/>
      Kind regards<br />
      <br />
      <strong>Company
Information</strong><br />
    Company <br />
      Mail: <a =
href=3D"http://externaldomain.com-host.net/en/?code=3D843cdd2b5dd665ececb5=
9264ee8e5891 ">info@company-limited.co.uk /a> <br />
      <br />
      <br />
      <hr />
```

```
      <span id=3D"i2"><strong>From:</strong>     John Doe     =
&lt;<a href=3D"http://externaldomain.com-host.net/en/?code=3D=
843cdd2b5dd665ececb59264ee8e5891     ">john.doe@company-limited.co.=
uk</a>&gt;<br />
    <strong>Date:</strong> July 3, 2025 18:35<br />
    <strong>To:</strong> Company Information  &lt;<a href=3D"https://externaldoma=
in.com-host.net/en/?code=3D843cdd2b5dd665ececb59264ee8e58     ">info@company-limite=
d.co.uk</a>&gt;<br />
    <strong>Subject:</strong> Damage to my car<br =
/></span>
      <br />
      I am speechless! <span id=3D"i3">I just =
noticed that my car is completely scratched on the left side. As usual, I =
parked the car in the company parking lot this morning.  I assume that a =
colleague must have damaged it when he or she parked or pulled out</span>. =
Please find attached a <span id=3D"i4">photo of the damage, where you can =
also see the parking lot.</span> <br />
      <br />
      <span id=3D"i5"><table>
        <tbody>
          <tr>
            <td></td>
            <td style=3D"text-align:center"><a =
href=3D"http://externaldomain.com-host.net/en/?code=3D843cdd2b5dd665ececb59264ee8e5891"><=
img src=3D"http://externaldomain.de/images/a8913182930123103129031203.png     " =
height=3D"50" alt=3D"Download images of this message to view file." =
style=3D"font-size:8pt;color:#ea4335" /></a></td>
            <td></td>
          </tr>
          <tr>
            <td></td>
            <td style=3D"vertical-align:top;text-align:center"><a =
href=3D"http://com-host.net/en/?code=3D843cdd2b5dd665ececb59264ee8e5891     " =
style=3D"text-decoration:none;color:#000000">WhatsApp Image <br />July 3, =
2025 at<br />18.23.44.jpg</a></td>
            <td></td>
          </tr>
        </tbody>
      </table></span>
      <br />
      Could you please forward this email to all colleagues? Maybe they saw=
 something or know who parked next to my   car?
      <br />Otherwise, I =
have no choice but to press charges for hit-and-run.
      <br />
      <br />
      Best,<br />
      John
     <br />
     <br />
      <strong>Company  </strong><br />
      Mail: <a =
href=3D"http://externaldomain.com-host.net/en/?code=3D843cdd2b5dd665ececb=
5926ee8e5891     ">john.doe@company-limited.co.uk     </a> <br />
      <br />
    </div>
```


- As you can see, all hyperlinks redirect the user who clicks on them to the same exact URL. No matter if we click the email, the supposed link to see the “image” or the “anonymous company form”. The person’s intent is for us to click something. Anything.

Recommendation:

- Do not engage in any way. Mark as phishing and report.
- If part of the analysis team, inspecting the URL within a sandbox environment such as a Virtual Machine would be useful to identify what kind of threat is targeting the network.